Incident Report: Phishing-Based Mailbox Compromise

Alert Title

Suspicious Email Activity Following Phishing Link Click

Summary

User `sara.ali` received and interacted with a phishing email that redirected to a malicious site. Shortly after, a successful login was observed from an unusual location using a new device without MFA enforcement. Following the login, suspicious mailbox rules were created and emails were forwarded externally, indicating account compromise and data exfiltration.

Initial Findings

- User: `sara.ali`
- Email Subject: *"Important: Account Verification Required"*
- Sender: `security-update@accountverify-login.com`
- Phishing link clicked: Yes
- Successful Login (4624)
- IP: `45.88.190.12`
- Location: Ukraine
- Device: Chrome (Linux)
- MFA: Not triggered

Key Observations

- Suspicious email domain
- User interaction with phishing link
- Login from unusual location
- New device used
- MFA not triggered
- Malicious mailbox rule created

- Email forwarding to external address
- High volume mailbox access

Investigation

```
SecurityEvent
| where EventID == 4624
| where Account == "sara.ali"
| where IPAddress == "45.88.190.12"
| project TimeGenerated, IPAddress
```

Mailbox Activity

- Forwarding rule detected
- Emails marked as read automatically
- Bulk email access observed

Evidence

- Phishing email interaction
- Suspicious login
- Mailbox rule creation
- External forwarding address
- Abnormal mailbox activity

Conclusion

This incident is classified as a **Confirmed True Positive (Phishing-Based Account Compromise with Data Exfiltration)**.
The attacker gained access and established persistence via mailbox rules while exfiltrating sensitive data.

Severity

Critical

Response Actions

- Account disabled temporarily
- Password reset enforced
- Sessions revoked
- Malicious mailbox rules removed
- Email forwarding disabled
- Escalated to Tier 2

Analyst Note

This incident demonstrates the critical impact of phishing attacks and the need for user awareness training, MFA enforcement, and detection of suspicious mailbox rule creation.